

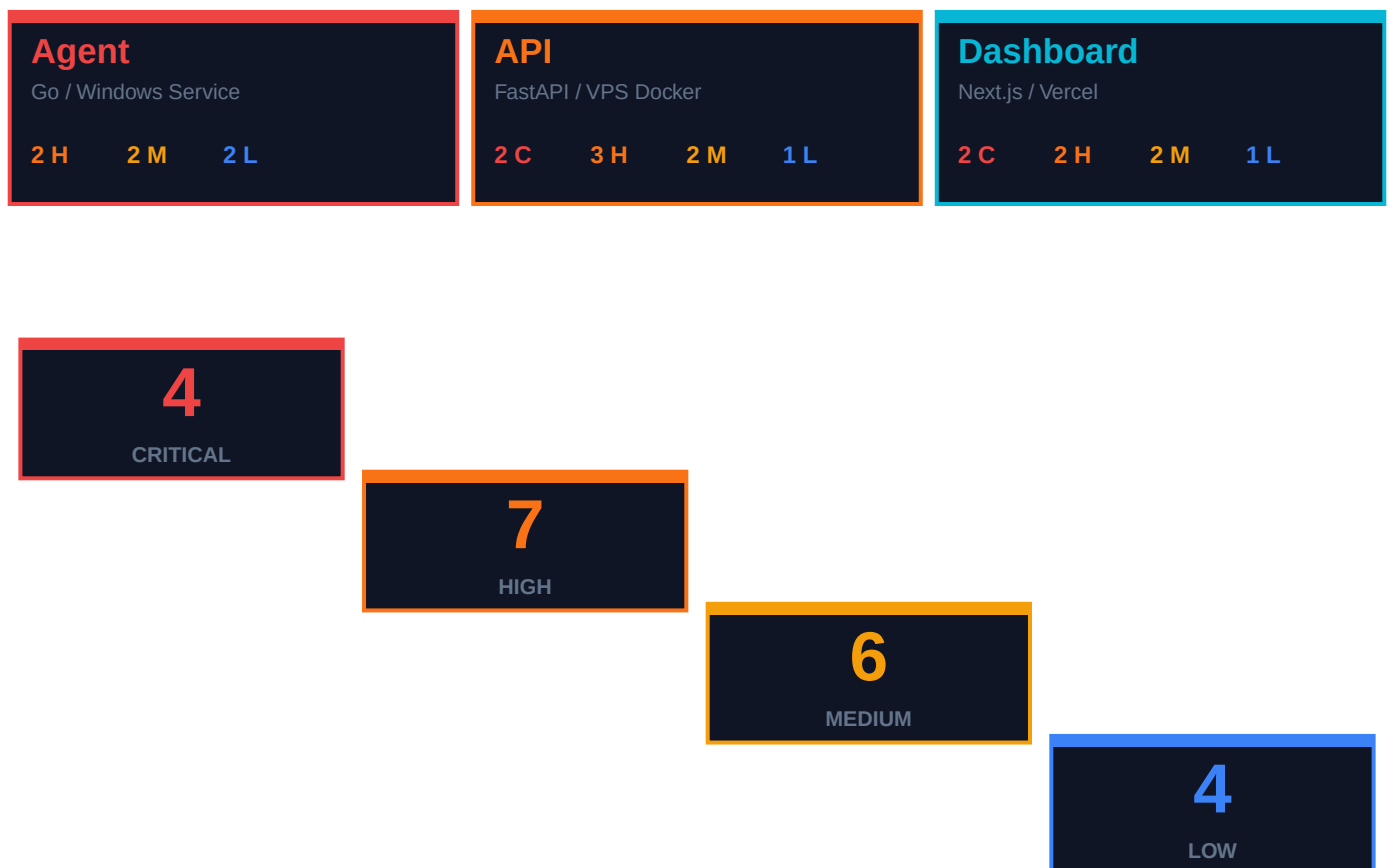


SentinelEdge Ecosystem

Security Audit Report -- Analisis Integral del Ecosistema MSP

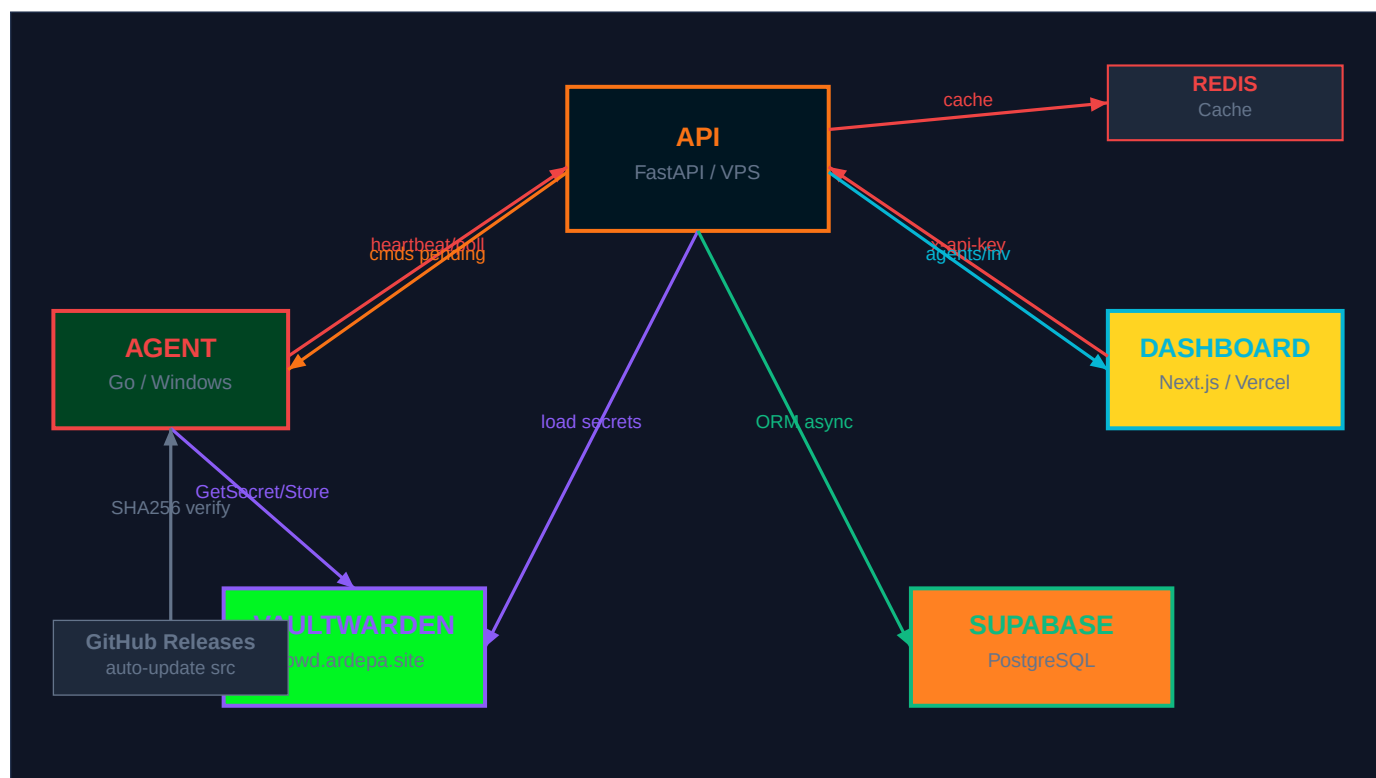
Fecha: 2026-03-20 Autor: Claude Code Security Audit Confidencial

Este reporte presenta una vision integral de la seguridad del ecosistema SentinelEdge compuesto por tres componentes interconectados: el Agente Windows (Go), la API central (FastAPI/Python), y el Dashboard (Next.js/Vercel). Se analizan las vulnerabilidades de cada componente, los vectores de ataque cross-componente, y la arquitectura de confianza del sistema. El objetivo es identificar la cadena de compromiso completa y proporcionar un roadmap de remediacion priorizado por impacto real.



Total global: 21 hallazgos en 3 proyectos

El ecosistema SentinelEdge opera con un modelo pull-based: el Agente hace polling activo a la API cada 30 segundos. Ningun componente empuja datos sin ser solicitado. La confianza se establece mediante tokens Bearer (Agente hacia API), API Keys (Dashboard hacia API), y OAuth client_credentials (ambos componentes hacia Vaultwarden).



Cadena 1 -- Compromiso Total desde el Browser (CRITICO)

- | | | |
|---|---|---|
| 1 | Atacante visita el dashboard en Vercel (URL publica) | Acceso libre, sin credenciales necesarias |
| 2 | Abre DevTools del navegador, busca la API key en el bundle JS | Encuentra DASHBOARD_API_KEY en texto claro en el bundle |
| 3 | Ejecuta POST /commands con x-api-key via curl o script | Envia PowerShell arbitrario a cualquier agente registrado |
| 4 | El agente ejecuta el script con privilegios de sistema | Acceso total al endpoint Windows gestionado |
| 5 | Instala backdoor, exfiltra datos, o despliega ransomware | Sin rastro en audit logs, la API no sabe quien envio el comando |

Cadena 2 -- Supply Chain Attack via Auto-Update (HIGH)

- | | | |
|---|---|--|
| 1 | Atacante compromete el VPS de la API (via .env accesible) | Obtiene VAULT_CLIENT_SECRET del archivo .env |
| 2 | Accede a Vaultwarden con el secret, lee DASHBOARD_API_KEY | Tiene acceso completo a todos los secrets del ecosistema |
| 3 | Modifica endpoint GET /version con nuevo exe y hash malicioso | La URL de descarga y el SHA256 apuntan a su ejecutable |
| 4 | Envia comando "update" a todos los agentes registrados | Los agentes descargan y verifican SHA256 -- coincide |
| 5 | El ejecutable malicioso se instala en todos los endpoints | Propagacion masiva en una sola operacion coordinada |

Cadena 3 -- Reconocimiento sin Credenciales (HIGH)

- | | | |
|---|---|---|
| 1 | Atacante llama GET /agents?tenant_id=tenant-sentineledge | Sin credenciales, retorna lista completa de agentes |
| 2 | Obtiene hostnames, OS, estado online de todos los endpoints | Mapeo completo de infraestructura del cliente del MSP |
| 3 | Combina con GET /agents/inventory/{id} para cada agente | IPs, software instalado, hardware, numeros de serie |
| 4 | Identifica targets de alto valor y vulnerabilidades conocidas | Servidores criticos, software desactualizado, endpoints expuestos |

Fase 1 -- Inmediato (Esta Semana)

- Dashboard: Crear Route Handler `/api/command` server-side, eliminar prefijo `NEXT_PUBLIC_` de la API key
- Dashboard: Implementar autenticacion de usuario con NextAuth.js (Credentials o Microsoft SSO)
- API: Hashear `Agent.token` usando `hash_token()` ya existente en `core/security.py`
- API: Agregar autenticacion en `GET /agents` (requerir `x-api-key`)

Fase 2 -- Corto Plazo (Este Mes)

- API: Validar `tenant_id` en `POST /commands` -- verificar ownership del agente
- API: Configurar rate limiting en nginx-proxy para todos los endpoints de agentes
- API: Cambiar CORS de wildcard a URL exacta del dashboard en produccion
- Dashboard: Agregar HTTP Security Headers completos en `next.config.ts`
- Agent: Implementar backoff exponencial con jitter en el poll loop

Fase 3 -- Mediano Plazo (Proximo Trimestre)

- Agent: Implementar whitelist de scripts PowerShell permitidos por hash SHA256
- Agent: Cifrar `VaultClientSecret` con DPAPI o Windows Credential Manager
- API: Implementar audit log completo -- actor, accion, timestamp, origen
- Agent: Agregar firma `Authenticode` al ejecutable para auto-update seguro
- Ecosistema: Implementar rotacion automatica de tokens cada 30 dias

Fase 4 -- Largo Plazo (Siguiete Semestre)

- Agent: Certificate pinning contra `saapi.ardepa.site` en conexiones TLS
- API: Tokens por sesion de usuario en lugar de una sola `DASHBOARD_API_KEY`
- Ecosistema: Penetration test externo por tercero certificado (OSCP/CREST)
- Documentacion: Runbook de respuesta a incidentes y proceso de rotacion de secrets

#	Proyecto	Severidad	Area	Hallazgo
1	Agent	HIGH	Command Execution	Ejecucion de PowerShell arbitrario sin whitelist de comandos
2	Agent	HIGH	Configuracion	VaultClientSecret en texto plano en agent.yaml
3	Agent	MEDIUM	Auto-Update	Hash SHA256 para auto-update proviene del mismo servidor potencialmente comprometido
4	Agent	MEDIUM	Resiliencia	Sin backoff exponencial en polling -- posible thundering herd
5	Agent	LOW	Seguridad TLS	Sin certificate pinning contra saapi.ardepa.site
6	Agent	LOW	Tokens	Tokens de agente sin expiracion ni rotacion automatica
7	API	CRITICAL	Auth & Tokens	Agent.token almacenado en texto plano en Supabase
8	API	CRITICAL	Auth & Access	GET /agents lista todos los agentes sin autenticacion
9	API	HIGH	IDOR	Sin validacion de tenant en /commands -- IDOR cross-tenant
10	API	HIGH	Rate Limiting	Sin rate limiting en endpoints de agentes
11	API	HIGH	CORS	CORS permite todos los proyectos de Vercel (wildcard *.vercel.app)
12	API	MEDIUM	Configuracion	VAULT_CLIENT_SECRET en .env del VPS sin rotacion documentada
13	API	MEDIUM	Infra	Servicio postgres legacy en docker-compose -- superficie de ataque innecesaria
14	API	LOW	Auth & Tokens	Single DASHBOARD_API_KEY estatica para todo el trafico del dashboard
15	Dashboard	CRITICAL	Secrets	NEXT_PUBLIC_DASHBOARD_API_KEY expuesta en el bundle del browser
16	Dashboard	CRITICAL	Auth & Access	Dashboard completamente publico -- sin autenticacion de usuario
17	Dashboard	HIGH	Headers HTTP	Sin HTTP Security Headers -- next.config.ts vacio
18	Dashboard	HIGH	XSS	Output de comandos PowerShell renderizado sin verificacion de sanitizacion
19	Dashboard	MEDIUM	Configuracion	.env.local creado desde PowerShell con potencial BOM UTF-8
20	Dashboard	MEDIUM	Frontend	Light theme roto en /agents/[id] -- Tailwind hardcoded vs CSS vars
21	Dashboard	LOW	UX / Seguridad	RebootModal permite envio de comandos repetidamente sin confirmacion adicional

